

IDP 보안 감사 리포트 (레드팀 전수감사)

대상 프로젝트: `mack-erel/idp` — SvelteKit + Cloudflare Workers + D1 기반 Identity Provider (OIDC / SAML / WebAuthn / LDAP) 감사 일시: 2026-05-12 감사 브랜치: `feat/root-account-hub` (HEAD: `281717c`) 감사 방식: 외부 침입(red-team) 시나리오 기반 — 실제 익스플로잇 가능성 중심, 8개 영역 병렬 전수감사 감사 범위: 110개 소스 파일 + 설정/시크릿/CI/배포/의존성 전수 감사 영역:

- 1. OIDC provider (`authorize/token/userinfo/jwks/end-session/discovery` + `admin`)
- 2. SAML provider (`sso/slo/metadata` + `admin`)
- 3. 인증/세션/MFA/WebAuthn
- 4. 관리자 UI / 조직(부서·팀·파트·직급) / DB 스키마 / 감사 로그 / 스킨 / LDAP
- 5. 설정 / 시크릿 / CI/CD / 배포
- 6. XSS / CSP / 보안 헤더 / 프론트엔드
- 7. 공통 API / 메일 / SSRF
- 8. 의존성 CVE / 공급망

1. Executive Summary

본 IDP 의 코드 품질은 일반 OSS IDP 평균보다 명백히 높다. PKCE S256 강제, authorization code 원자 소진, WebAuthn challenge 1회용 + dummy publicKey timing equalization, SAML AuthnRequest replay + DTD/ENTITY 차단, exc-c14n, session fixation 방지, TOTP secret AES-GCM + userId AAD, LDAP filter/DN 이스케이프, redirect double-decoding 등 IDP 가 실수하기 쉬운 지점 대부분이 정확히 막혀 있다.

그러나 (1) 운영 위생 — `.env` 평문 시크릿, (2) 공급망 — CI workflow 자동 commit + PAT, 비공식 의존성 fork, (3) 관리자 멀티테넌트 IDOR / `last-admin` 보호 race, (4) 외부 신뢰 모델 — skin HTML, DNS, LDAP fork 4축에서 사고가 터지면 코드 품질이 무의미해진다. 발견된 Critical 14건 중 9건이 이 4축에 집중되어 있다.

Risk Level: **CRITICAL**

누적 발견 통계

Severity	합계	대표 사례
Critical	11건	CI workflow PAT exfiltration, authorization code 평문 저장, SAML SLO 서명 우회, find-password Host header injection, skin SSRF DNS rebinding, cross-tenant IDOR, 부서 트리 순환
High	25건	wildcard redirect_uri, JWT typ/crit 미검증, CSRF_SKIP 광범위, audit log 무결성 부재, signing-key rotate race, argon2 파라미터 OWASP 미달, @hicar/argon2-pure.js 0.0.x 가 패스워드 해싱 경로에 실사용
Medium	30건	CSP form-action 사실상 무제한, csrf.trustedOrigins=["*"], SAML LogoutResponse XML 파싱 0, signup vs login 정규화 비대칭(homoglyph), @yrneh_jang/ldapjs self-fork upstream patch lag
Low	22건	HSTS preload 미설정, COEP 미설정, tsconfig strict 옵션 부족

정정 사항 (2026-05-12 본 리포트 작성 후 실측 결과 반영)

원래 평가	실측 결과	정정

nodemailer^8.0.5 메이저 비실재 의심	nodemailer@8.0.7 정상 존재	정상
typescript^6.0.2 메이저 비실재 의심	6.0.3 정상	정상
eslint^10, vite^8 메이저 비실재 의심	10.3.0, 8.0.12 정상	정상
@yrneh_jang/ldapjs 외부 maintainer fork (Critical)	mack-erel org 의 self-fork (mack-erel/node-ldapjs). 외부 공급망 아님	Medium 으로 강등 (upstream patch lag risk)
@xmldom/xmldom 0.9.9 (4 high CVE)	bun update 로 0.9.10 적용 완료 (CVE 4 건 해소)	해결 완료

1.1. 감사 중 즉시 적용된 조치 (Already Applied)

- ✅ @xmldom/xmldom 0.9.9 → 0.9.10 (bun update) — High 4건 CVE 해소 (GHSA-2v35-w6hq-6mfw / GHSA-f6ww-3ggp-fr8h / GHSA-x6wf-f3px-wcqx / GHSA-j759-j44w-7fr8)
- ✅ git history 시크릿 검사 통과: gitLeaks detect --log-opts="--all" → no leaks found (false positive 1건 .gitLeaksignore 처리)
- ✅ CI 의존성 audit 게이트 추가: .github/workflows/ci.yml 에 bun audit --audit-level=high 단계 추가 → High 이상 신규 발견 시 PR 머지 차단
- ✅ 남은 의존성 vuln 3건 (postcss/esbuild/cookie): 모두 transitive dev-only + practical risk 낮음으로 무시 결정. Major upstream (vite/wrangler/kit) 다음 릴리스에서 자연 해결 대기
- ✅ C-1, C-2 (.env / wrangler.jsonc 평문 시크릿) 등급 재평가: 사용자 확인 결과 .env / wrangler.jsonc vars 의 값은 로컬 dev 전용이며 production 시크릿은 wrangler secret put 으로 별도 관리됨이 확인됨. Git history 도 깨끗. → **Critical** 등급 제거 (dev 머신 위생 항목으로 강등, Low 분류). 회전 작업 불요.

2. 사전 안전 조치 (Bash 권한이 거부되어 사용자 직접 실행 필요)

```
# 시크릿 history 검사
git log --all -p -- .env wrangler.jsonc \
  | grep -E "IDP_SIGNING_KEY_SECRET|CLOUDFLARE_D1_TOKEN|github_pat_|SMTP_PASSWORD"
gitLeaks detect --log-opts="--all" --no-git=false --redact

# 의존성 CVE 실측
bun audit
bunx osv-scanner --lockfile=bun.lock
bun pm ls --all | grep -E "nodemailer|argon2|ldapjs|typescript|eslint|vite"

# 비실재/비정상 메이저 확인
npm view eslint versions --json | tail -20
npm view typescript versions --json | tail -10
npm view vite versions --json | tail -10
npm view nodemailer versions --json | tail -10
npm view @yrneh_jang/ldapjs maintainers time
```

```
# 운영 secret 위치 확인
wrangler secret list
```

3. Critical Findings (11건) — 즉시 조치

C-1. `.env` 평문 / C-2. `wrangler.jsonc` - `vars` → 등급 제거 (Low / 운영 위생)

원래 **Severity**: Critical → 재평가 후 Low

재평가 사유: 사용자 확인 결과 `.env` 와 `wrangler.jsonc` `vars` 의 값은 로컬 **dev** 전용이며 production 시크릿은 `wrangler secret put` 으로 별도 관리됨이 확인됨. `.gitignore` 처리 정상, `git history` `git leaks` `no leaks found` , 외부 노출 경로 없음. → 시크릿 회전 불요.

남는 권장 (Low):

- FileVault 디스크 암호화 ON
- iCloud/Dropbox/Time Machine 가 `.env` 가 들어있는 디렉토리 동기화 안 하는지 확인
- IDE AI/telemetry 가 `.env` 안 읽도록 `.cursorignore` / IDE 설정
- 향후 production 시크릿을 실수로 `.env` 에 넣지 않도록 `.env.example` 만 dev placeholder 유지

C-3. CI `format` job 의 PAT 자동 commit 패턴 — 공급망 RCE

파일: `/Users/henry/github/mack-erel/idp/.github/workflows/ci.yml:42-72` **Severity**: Critical

```
- uses: actions/checkout@v6
  with:
    token: ${ secrets.WORKFLOW_PAT || secrets.GITHUB_TOKEN }
- run: bun install
- run: bun run format
- uses: stefanzweifel/git-auto-commit-action@v7
```

공격 시나리오:

1. PR 작성자가 `prettier.config.js` , `prettier-plugin-tailwindcss` , 또는 `eslint.config.js` 를 악의적으로 수정 (prettier plugin 은 임의 JS).
2. `bun install` 또는 `bun run format` 실행 단계에서 임의 코드 실행.
3. `secrets.WORKFLOW_PAT` 가 환경에 주입되어 있어 탈취.
4. PAT 권한으로 main 직커밋 + branch protection 우회 가능 → 다음 `deploy.yml` 이 main push 트리거로 Cloudflare 자동 배포 → **IDP 자체 백도어 코드**.

Remediation:

- format 단계를 `workflow_run` 으로 분리해 격리, 또는 자동 commit 제거(작성자가 로컬에서 `lint:fix`).
- `WORKFLOW_PAT` 를 GitHub App token 으로 대체.
- `bun install --frozen-lockfile --ignore-scripts` 강제.

C-4. `deploy.yml` 의 shell injection 패턴

파일: `/Users/henry/github/mack-erel/idp/.github/workflows/deploy.yml:63-64` **Severity**: Critical

```
- name: Setup Wrangler config
  run: echo '${{ secrets.WRANGLER_JSONC }}' > wrangler.jsonc
```

시크릿이 단일 따옴표 안에 직접 보간 → 시크릿에 ' 가 포함되면 shell quote 깨져 임의 명령 실행. GitHub Actions 마스킹은 출력에만 적용되며 syntax injection 은 막지 못한다.

Remediation:

```
- name: Setup Wrangler config
  env:
    WRANGLER_JSONC: ${ secrets.WRANGLER_JSONC }
  run: printf '%s' "$WRANGLER_JSONC" > wrangler.jsonc
```

C-5. @yrneh_jang/ldapjs -비공식 fork → Medium 으로 강등 (M-DEP-1 참조)

정정: 실측 결과 @yrneh_jang/ldapjs 는 외부 maintainer 패키지가 아니라 mack-erel org (이 IDP 와 동일 owner) 의 self-fork (mack-erel/node-ldapjs) 임이 확인됨. Cloudflare Workers 호환을 위한 fork.

→ "외부 npm maintainer 손상" 시나리오 소멸. Critical 등급 부적절. **Medium (upstream ldapjs 보안 패치 동기화 책임이 본인에게 있음)** 으로 강등하여 본 문서 후반의 Medium 섹션 참조.

C-6. Authorization code 가 D1 에 평문 저장

파일: src/routes/oidc/authorize/+server.ts:150-165 , src/lib/server/oidc/grant.ts:24-44

Category: A02 / A04 Severity: Critical

```
const code = crypto.randomUUID().replace(/-/g, '') +
crypto.randomUUID().replace(/-/g, '');
await createGrant(db, { code, ... }); // ← 평문 저장
```

공격 경로: D1 read-replica · 로그 dump · 백업 유출 · readonly admin. authorize 직후 5분 내 평문 code 읽히면 token 교환 가능.

PoC: SELECT code, client_id, redirect_uri FROM oidc_grants WHERE used_at IS NULL; → POST /oidc/token .

Remediation: code 는 client 에만 노출, DB 에는 SHA-256 해시 저장.

```
const code = b64uEncode(crypto.getRandomValues(new Uint8Array(32)));
const codeHash = b64uEncode(await crypto.subtle.digest("SHA-256", new
TextEncoder().encode(code)));
await createGrant(db, { codeHash, ... });
```

C-7. end-session GET 의 인증 무관 confirm 페이지 + clickjacking

파일: src/routes/oidc/end-session/+server.ts:70-128 Severity: Critical

GET 핸들러가 locals.user 가 null 이어도 id_token_hint 만 valid 면 confirm 페이지를 렌더. frame-ancestors / X-Frame-Options 응답 헤더 부재.

공격:

```
<iframe src="https://idp.example.com/oidc/end-session?id_token_hint=<leaked>">
</iframe>
<!-- UI redress 로 [로그아웃] 버튼 클릭 강제 -->
```

또는 phishing 메일로 IDP 공식 도메인의 confirm 페이지를 표시 → 사용자가 의심 없이 클릭 → 강제 로그아웃.

Remediation:

- 응답에 X-Frame-Options: DENY, Content-Security-Policy: frame-ancestors 'none'; default-src 'none'; form-action 'self', Cache-Control: no-store.
- locals.user 미존재 시 GET 단계에서 204 반환.
- confirm form 에 server-signed CSRF token.

C-8. SAML SP cert 미등록 시 LogoutRequest 서명 검증 우회

파일: src/routes/saml/slo/+server.ts:271-277 Severity: Critical

```
if (sp.cert) {
  const valid = await verifySamlRedirectSignature(rawQuery, sp.cert);
  if (!valid) throw error(400, "Invalid SAMLRequest signature");
}
```

sp.cert IS NULL 이면 모든 SP-initiated LogoutRequest 가 서명 검증 없이 신뢰됨. 공격자가 임의 entityId 로 LogoutRequest 위조 → 피해자 IdP 세션 revoke + SLO 체인 트리거 → 모든 연결 SP 로 LogoutRequest 발사.

Remediation:

```
if (!sp.cert) throw error(400, "SP 인증서가 등록되지 않아 SLO 요청을 검증할 수 없습니다.");
const valid = await verifySamlRedirectSignature(rawQuery, sp.cert);
if (!valid) throw error(400, "Invalid SAMLRequest signature");
if (!url.searchParams.has("Signature")) throw error(400, "LogoutRequest 는 반드시 서명되어야 합니다.");
```

또한 admin SP 등록 액션에서 SLO 활성 SP 는 cert 필수로 강제.

C-9. SAML SLO 체인 응답에 세션-state binding 없음

파일: src/routes/saml/slo/+server.ts:160-225 Severity: Critical

initiatingSpEntityId 가 NULL 또는 SP cert NULL 일 때 LogoutResponse 서명 검증 완전 스킵. stateId 만 알면 누구나 SLO 체인 진전 가능 → IdP 가 서명한 LogoutRequest 임의 발사.

Remediation:

- LogoutResponse 도 SP cert 필수.
- IdP-initiated 체인의 경우 locals.session?.id === state.idpSessionRecordId 일관성 검사 추가.

C-10. find-password Host header injection → 계정 takeover

파일: src/routes/(auth)/find-password/+page.server.ts:105-112 **Category:** A07 / Identity
Recovery **Severity:** Critical

```
const issuer = (env.IDP_ISSUER_URL ?? event.url.origin)
    .replace(/\/+$/, "").replace(/\/+$/, "");
const resetUrl = `${issuer}/reset-password?${resetParams.toString()}`;
```

IDP_ISSUER_URL 누락 시 event.url.origin fallback 은 Host 헤더에 의존. 공격자가 Host: evil.com 으로
폼 제출 → victim 메일 본문에 https://evil.com/reset-password?token=<유효토큰> 박혀서 발송 → victim 이 클
릭하면 토큰 유출 → 1시간 내 계정 takeover.

Remediation:

```
const issuer = env.IDP_ISSUER_URL?.replace(/\/+$/, "");
if (!issuer) return fail(503, { error: "메일 발송 설정 오류가 있습니다." });
```

C-11. 부서 트리 간접 순환 참조 무방어

파일: src/routes/admin/departments/+page.server.ts:60-73 **Severity:** Critical

parentId === id 직접 순환만 차단. 간접 순환(A→B→A, A→B→C→A) 미검증 → 트리 traversal 무한루프 → Workers
CPU 타임아웃, 권한 상속 계산 붕괴.

PoC:

```
POST /admin/departments?/update { id=A, parentId=B }
POST /admin/departments?/update { id=B, parentId=A } ← 통과
```

Remediation: update 전 parentId 부터 root 까지 traversal 하여 id 가 조상에 있는지 검사 + depth ≤ 8 제한.

C-12. Last-admin 보호 self/race 우회

파일: src/routes/admin/users/[id]/+page.server.ts:160-251 **Severity:** Critical

updateProfile 의 self-prevention 이 "값 다를 때만" 차단. admin A, B 두 명 상황에서 A 가 B 의 role 변경 후 본인 갱신
race 시 last-admin 보호 우회 가능.

Remediation: assertNotLastAdmin 을 self 케이스에도 호출. 자기 자신 role/status 변경 자체를 항상 차단 (값 일치 여
부 무관).

C-13. addAssignment cross-tenant IDOR

파일: src/routes/admin/users/[id]/+page.server.ts:482-580 **Severity:** Critical

addAssignment/addDept/addTeam/addPart action 들이 params.id 의 tenant 검증 없이
userServiceAssignments INSERT. 테넌트 X admin 이 /admin/users/<tenant-Y-user-id> POST 하면
cross-tenant 권한 row 생성. 현재 single-tenant 라 임팩트 제한, 멀티테넌트 활성화 즉시 폭발.

Remediation: 모든 admin [id] action 진입부에서 select users where id=params.id AND
tenantId=tenant.id .

C-14. Skin SSRF DNS rebinding + 외부 HTML {@html} 무제한 주입

파일:

- `src/lib/server/skin/resolver.ts:26-44` (SSRF)
- `src/routes/(auth)/{login,signup,mfa,reset-password,find-id,find-password}/+page.svelte` (6개소 {@html})

Severity: Critical

SSRF DNS rebinding: `isFetchUrlAllowed` 가 hostname 문자열만 검증. fetch 시점에 DNS 재해석되므로 `evil.com` 의 A 레코드를 일시적으로 공인 IP 로 응답해 통과 → 실제 요청 시 `10.0.0.1` . Workers `fetch()` 는 IP pinning 보장 안 함.

{@html} 주입: admin 이 등록한 외부 https 호스트가 한 번이라도 침해되면 모든 로그인/MFA/회원가입 페이지에 임의 HTML 주입. CSP `script-src 'self'` 는 인라인 차단하지만 `form-action 'self' https:` 가 풀려있어 `<form action="https://attacker.tld">` 그대로 통과 → credential 평문 전송.

Remediation:

- 단기:
 - DOMPurify 로 sanitize: `<script>` , `<iframe>` , `<form action>` 외부, `on*` 핸들러, `<base>` , `<meta http-equiv>` 제거.
 - SSRF: timeout(5s), Content-Length/스트림 상한(512KB), IPv6 literal 거절, `*.internal / metadata.google.internal / 0.x` 차단.
- 장기:
 - SRI 유사 content hash pinning (admin 등록 시 SHA-256 입력, fetch 시 비교).
 - 메인 도메인과 분리된 origin 에서 격리 렌더.
 - 또는 마크업은 IDP 가 소유하고 스킨은 JSON(컬러/카피)만 받는 구조로 전환.

4. High Findings (25건 요약)

OIDC (6)

- **H-OIDC-1:** `verifyIdToken` 이 `typ / crit` 헤더 미검증 → `logout+jwt` 가 `id_token_hint` 자리 통과 (`crypto/keys.ts:139-181`).
- **H-OIDC-2:** `userinfo` 호출 시 `expectedAud` 미강제 → cross-client access token reuse.
- **H-OIDC-3:** `parseBasicAuth` 가 `atob` throw 미처리 + public client 빈 secret 통과 (`oidc/client.ts:17-29`).
- **H-OIDC-4:** wildcard `redirect_uri` (`pr*.ctrls.kr`) — admin 부주의 등록 + subdomain takeover 시 폭발 (`oidc/client.ts:64-104`).
- **H-OIDC-5:** admin `regenerateSecret / delete / update` 액션 명시적 CSRF 토큰 없음 (`admin/oidc-clients/+page.server.ts:215-337`).
- **H-OIDC-6:** frontchannel logout iframe `sandbox="allow-scripts"` 만 — CSP 부재 (`end-session/+server.ts:14-27`).

SAML (5)

- **H-SAML-1:** `signResponse=false` + `signAssertion=true` 조합 허용 → SP XSW 노출.
- **H-SAML-2:** SAMLRequest parameter pollution (`SAMLRequest=A&SAMLRequest=B`) → 서명검증/파싱 mismatch.
- **H-SAML-3:** SHA-1 SigAlg 기본 허용 (`parse-authn-request.ts:80-83`).

- **H-SAML-4:** admin SP update 액션에 audit 로깅 0개 — ACS URL 교체/cert 교체 무흔적 (admin/saml-sps/+page.server.ts:144-190).
- **H-SAML-5:** xmldom errorHandler 미지정 → 부분 파싱 silent fail 가능.

인증/세션/MFA (5)

- **H-AUTH-1:** CSRF_SKIP 에 ^/oidc/ 광범위 패턴 — /oidc/end-session POST 등 사이드이펙트 라우트 스킵 (hooks.server.ts:9-16).
- **H-AUTH-2:** /api/webauthn/authenticate/options rate-limit 없음 → 익명 챌린지 무한 발급 → D1 storage exhaustion.
- **H-AUTH-3:** verifyPasskeyAuthentication SELECT 에 users.status='active' 누락 → 비활성 사용자 verify 통과.
- **H-AUTH-4:** argon2id m=4MB, t=3 OWASP 최소(m=19MB, t=2 또는 m=12MB, t=3) 미달 (auth/password.ts:15-24).
- **H-AUTH-5:** /account/passkeys 삭제 시 step-up 재인증 없음 — 세션 탈취 공격자가 최우선으로 패스키 삭제.

관리자/조직/DB (4)

- **H-ADMIN-1:** departments/teams/parts/positions/signing-keys 의 create/update/delete 에 audit log 0 건.
- **H-ADMIN-2:** audit log 무결성 보장 부재 — append-only/chained hash/Logpush mirror 없음.
- **H-ADMIN-3:** getRequestMetadata 의 X-Forwarded-For fallback (audit/index.ts:18-19) — Workers 외부 노출/dev 환경에서 IP 위조.
- **H-ADMIN-4:** LDAP bindPassword 평문/암호화 공존 + encryptBindPassword 가 signingKeySecret 없으면 평문 silent fallback.
- **H-ADMIN-5:** signing-key rotate 4단계가 트랜잭션 아님 → 동시 rotate 시 active 키 2개.

프론트/CSP (3)

- **H-FRONT-1:** meta refresh redirectTo scheme 검증 없음 → admin 이 javascript: URI 등록 시 IDP 컨텍스트에서 JS 실행 (end-session/+server.ts:21).
- **H-FRONT-2:** passkey-client 가 input[name="redirectTo"] DOM value 신뢰 — 외부 스킴이 hidden input 주입.
- **H-FRONT-3:** replacePlaceholders 컨텍스트 무관 escape — IDP_MASKED_USERNAME 이 href/src 컨텍스트로 쓰이면 XSS.

의존성 (1)

- **H-DEP-1:** @hicaru/argon2-pure.js ^0.0.4 (0.0.x 비공식, 단일 maintainer) — src/lib/server/auth/password.ts:12 에서 hashEncoded / verifyEncoded 로 패스워드 해시/검증 신뢰 뿌리에 실사용 확인됨. timing safety/사이드채널 미보장 + maintainer 손상 시 DB 의 모든 해시가 사실상 평문 화될 우려.

메일 (1)

- **H-MAIL-1:** email.ts 의 username / resetUrl HTML escape 없이 템플릿 보간.

Seed (1)

- **H-SEED-1:** seed.ts 의 PBKDF2-SHA256 100k iter (OWASP 2023 권고 600k SHA-256 / 210k SHA-512 미달).

5. Medium Findings (29건 요약)

영역	항목
----	----

CSP	form-action 'self' https: http://localhost:* 사실상 무제한; HSTS preload 미설정; COEP 미설정
CSRF	SvelteKit csrf.trustedOrigins: ["*"] 전역 비활성 (hooks 정규식에 100% 의존)
OIDC	token endpoint per-client rate-limit 없음; grant→session revocation 검증 없음; userinfo Vary: Authorization 부재; authorize rate-limit IP 단일; state 길이 제한 없음 (DB DoS); discovery 와 schema 의 refresh_token mismatch
SAML	LogoutResponse XML 파싱 0 (Issuer/Status/InResponseTo); SAML POST HTML 응답에 CSP 헤더 자체 없음; acsUrl 런타임 scheme 가드 부재; pendingSpDataJson 스키마 검증 없음; metadata Cache-Control: public + Vary 부재
Auth	signup vs login 정규화 비대칭 (NFKC 누락 → homoglyph 가입); 백업코드 timing leak; MFA pending IP 바인딩 IPv6/모바일 false-positive; 세션 IP/UA binding 없음; password reset 토큰 엔트 로피 외부 의존; cookie SameSite=Lax
DB	isPrimary=true 부서/팀 unique 없음; soft-delete 재가입 race; LDAP search multi-entry 첫 행만; provisionLdapUser random suffix race; skinType enum 검증 없이 cast
SSRF	DNS rebinding/IPv6/*.internal/0.x/timeout/body-size 보강 필요
Frontend	sanitizeRedirectTarget 원본 그대로 반환 (디코드 정규화 안 함); placeholder 미정의 키 silent empty; /api/skin-scripts X-Content-Type-Options 누락; find-id/password 액션 응답 Cache-Control: no-store 명시 부재
Infra	gitleaks 의 .env 미스캔 가능성; drizzle/ ignore 가 CLAUDE.md 정책과 충돌; CodeQL scripts/ 제외; D1 토큰 권한 미분리(read vs migrate); tsconfig noUncheckedIndexedAccess 등 누락; .mcp.json 외부 MCP 서버 신뢰; .npmrc ignore-scripts 미설정; profile 변경 시 audit 미기록

6. Low Findings (22건 요약)

영역	항목
Crypto	argon2 파라미터 OWASP 미달은 별도 H; PBKDF2 레거시 파라미터 검증 결함; generateClientId 80-bit hex slice
Cookie/CORS	COEP/COOP same-origin-allow-popups 향후 필요 가능성; Permissions-Policy usb=()/bluetooth=()/serial=() 등 보강 권장; Server-Timing 등 디버깅 정보 leak 확인 필요
Logging	audit detailJson 의 username 평문 보관 기간 정책 부재
SAML	xmlEscape 위치별 일관성 부족; metadata 멀티테넌트 public cache; Issuer descendant 검색; RelayState 길이 검증
Auth	revokeOtherSessions 다중 디바이스 비친화; revokeSession 인자명 혼란
Frontend	Server-Timing 정보 leak 가능성; parseBasicAuth 길이 가드 부재
Infra	gitignore *.bak/*.swp/*.log 명시 부재; tsconfig sourceMap: true 서버 노출 점검; docs/security-pentest-report.md 33KB public 노출 가능성; static/robots.txt 모든 크롤러 허용; seed.ts admin super-admin 자동 매핑 정책 문서화; CLAUDE.md 운영 정보 공개;

	webauthnChallenges.tenantId nullable 레거시; bunfig.toml/.npmrc allowlist 검토; CSRF skip 라우트 GET-only 확인
Other	nodemailer.createTransport 매 호출 생성; generateToken SQL WHERE tokenHash = ? timing; i18n t() 의 {@html} 호출처 확인 필요

7. 잘 막혀있는 항목 (정직)

영역	OK 항목
Injection	SQL injection (Drizzle 전수 parameterized, sql.raw 0개); LDAP filter/DN RFC 4515/4514 이스케이프
OIDC	PKCE S256 강제 + plain 거부; authorization code 원자 소진(UPDATE RETURNING); alg=none 거부; client_credentials/password/refresh_token grant 모두 거부
SAML	AuthnRequest replay (samlAuthnRequestIds unique + TTL); IssueInstant ±5분 skew; DTD/ENTITY 차단; exc-c14n; Destination/ACS 검증; 8KB/64KB 압축 폭탄 가드
WebAuthn	challenge DB 1회용 소진; tenantId 격리; 더미 publicKey 로 timing equalization; origin/rpID 매 요청 검증
Session	로그인 직후 revokeOtherSessions; password reset 토큰 SHA-256 해시 저장 + 사용 후 동일 user 다른 토큰 일괄 무효화
Crypto	AES-256-GCM + HKDF wrapping; IV/salt 매번 fresh; TOTP secret v2:\${userId} AAD bound; sessions 에 idpSessionId hash 저장
Authz	last-admin protection (일부 race 제외); IDOR boundary check (특정 액션 제외); OIDC end-session POST CSRF (Origin/Referer + id_token_hint)
Frontend	Svelte auto-escape; redirect 더블 디코딩 + control char/protocol-relative 차단; X-Frame-Options DENY + frame-ancestors none; nosniff; Referrer-Policy strict-origin-when-cross-origin
Audit	getRequestMetadata cf-connecting-ip 우선; rate-limit 슬라이딩 윈도우

8. 권장 조치 우선순위 로드맵

🚑 즉시 (1시간 내, 빠른 패치)

- C-4:** deploy.yml 의 echo → printf '%s' "\$VAR" 패턴 변경 (5분).
- C-7:** end-session GET 에 frame-ancestors: 'none' + locals.user null 시 204 (15분).
- C-8:** SAML SLO 에서 sp.cert NULL 시 거부 + Signature 파라미터 강제 (15분).
- C-10:** find-password 에서 IDP_ISSUER_URL 필수화 — 없으면 503 (5분).

🔴 이번 주 (Critical 코드 패치)

- C-3:** CI format job PAT 자동 commit 격리 (workflow_run 분리 또는 자동 commit 제거).
- C-9:** SAML SLO 체인 응답에 locals.session.id === state.idpSessionRecordId 일관성 검사 추가.
- C-11:** 부서 update 시 ancestor traversal cycle 검사 + depth ≤ 8.
- C-12:** last-admin self/race 케이스 단일 헬퍼(assertNotLastAdmin)로 통합.

9. **C-13**: 모든 admin [id] action 에 params.id tenant 검증 헬퍼 적용.
10. **C-14**: skin HTML DOMPurify sanitize + SSRF 가드 (timeout 5s, body-size 512KB, IPv6 literal/ *.internal / 0.x 차단). 장기적으로 SRI hash pin.

별도 maintenance window 필요

11. **C-6**: authorization code → SHA-256 hash 저장 (DB 마이그레이션 + 호환성 윈도우 필요).

C-1, C-2 (~~env + wrangler.jsonc~~ -평문): dev 전용 확인됨 — Low (운영 위생) 으로 강등. **C-5** (~~idp.js~~ -공급망): self-fork 확인됨 — Medium 으로 강등.

2주 내 (High 25건)

- CSP form-action: 'self' 복귀 (SAML 응답만 예외, per-route CSP)
- csrf.trustedOrigins 좁히기 + CSRF_SKIP 정규식 좁히기
- MFA pending token 1회용 nonce 화
- WebAuthn options rate-limit + status 필터
- 모든 admin route audit 로깅 추가 + chained hash + Logpush mirror
- signing-key rotate db.batch() 트랜잭션화
- SAML SHA-1 비활성, parameter pollution 가드
- OIDC typ / crit / expectedAud 검증
- third-party GH action SHA pin
- @hicar/argon2-pure.js 신뢰성 평가 또는 @node-rs/argon2 전환
- email.ts HTML escape

1개월 내 (Medium)

- 의존성 CVE 정기 audit CI (bun audit / osv-scanner) 통합
- partial unique index 마이그레이션 (isPrimary , soft-delete 재가입)
- SSRF DNS rebinding 가드 (DNS 사전 해석 + IP allowlist)
- tsconfig strict 옵션 강화
- HSTS preload 등록
- argon2 파라미터 WASM 전환 검토
- CodeQL scripts/ 포함
- gitleaks custom rule (.env 스캔)

백로그 (Low)

- Permissions-Policy 확장 (usb , bluetooth , serial)
- COEP require-corp
- audit detail PII 마스킹
- docs/security-pentest-report.md 와 본 문서를 public repo 외부로 이전

9. 영역별 핵심 파일 (절대 경로)

OIDC

- /Users/henry/github/mack-erel/idp/src/routes/oidc/authorize/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/oidc/token/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/oidc/end-session/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/oidc/userinfo/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/oidc/jwks/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/.well-known/openid-configuration/+server.ts

- /Users/henry/github/mack-erel/idp/src/lib/server/oidc/client.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/oidc/grant.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/oidc/pkce.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/oidc/logout.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/crypto/keys.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/oidc-clients/+page.server.ts

SAML

- /Users/henry/github/mack-erel/idp/src/routes/saml/sso/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/saml/slo/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/saml/metadata/+server.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/saml/parse-authn-request.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/saml/response.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/saml/slo.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/saml/sp.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/saml/metadata.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/saml-sps/+page.server.ts

인증/세션/MFA/WebAuthn

- /Users/henry/github/mack-erel/idp/src/hooks.server.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/auth/session.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/auth/password.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/auth/webauthn.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/auth/redirect.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/auth/users.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/login/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/mfa/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/signup/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/find-password/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/find-id/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/reset-password/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/api/webauthn/authenticate/options/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/api/webauthn/authenticate/verify/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/api/webauthn/register/verify/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/api/webauthn/passkey-client/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/account/passkeys/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/account/profile/+page.server.ts

관리자/조직/DB

- /Users/henry/github/mack-erel/idp/src/routes/admin/users/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/users/[id]/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/departments/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/teams/+page.server.ts

- /Users/henry/github/mack-erel/idp/src/routes/admin/parts/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/positions/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/skins/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/signing-keys/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/ldap-providers/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/routes/admin/audit/+page.server.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/audit/index.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/skin/resolver.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/ldap/auth.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/ldap/client.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/ldap/provision.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/ldap/types.ts
- /Users/henry/github/mack-erel/idp/src/lib/server/db/schema.ts

설정/CI/배포/의존성

- /Users/henry/github/mack-erel/idp/.env
- /Users/henry/github/mack-erel/idp/wrangler.jsonc
- /Users/henry/github/mack-erel/idp/package.json
- /Users/henry/github/mack-erel/idp/svelte.config.js
- /Users/henry/github/mack-erel/idp/tsconfig.json
- /Users/henry/github/mack-erel/idp/drizzle.config.ts
- /Users/henry/github/mack-erel/idp/.github/workflows/ci.yml
- /Users/henry/github/mack-erel/idp/.github/workflows/deploy.yml
- /Users/henry/github/mack-erel/idp/.github/workflows/gitleaks.yml
- /Users/henry/github/mack-erel/idp/scripts/seed.ts

프론트/이메일/공통

- /Users/henry/github/mack-erel/idp/src/lib/server/email.ts
- /Users/henry/github/mack-erel/idp/src/routes/api/skin-scripts/+server.ts
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/login/+page.svelte
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/signup/+page.svelte
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/mfa/+page.svelte
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/reset-password/+page.svelte
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/find-id/+page.svelte
- /Users/henry/github/mack-erel/idp/src/routes/(auth)/find-password/+page.svelte

10. 감사 방법론

본 감사는 8개 보안 감사 에이전트(security-reviewer + general-purpose)를 병렬 실행하여 수행되었다. 각 에이전트는 독립된 영역을 read-only 로 정독하고, 각 발견에 대해 (a) 파일:라인, (b) Severity(C/H/M/L), (c) OWASP 카테고리, (d) Exploitability, (e) Blast Radius, (f) 공격 시나리오/PoC, (g) Remediation 의 7-tuple 을 제출했다. 본 통합 리포트는 8개 결과의 중복 제거 + 우선순위 통합본이다.

범위 제약:

- Bash/WebFetch 권한이 일부 거부되어 bun audit / osv-scanner / npm view 실효는 미수행. 의존성 섹션은 사전 지식 기반 분석 + 사용자 실측 권장.
- Git history 폴스캔(gitleaks --log-opts="--all")은 미수행. 사용자 실측 필요.

- 운영 Cloudflare 시크릿 위치(`wrangler secret list`) 확인 못 함.
-

11. 마지막 한마디

이 IDP 의 핵심 코드 품질은 일반 OSS IDP 평균보다 명백히 높다. 의도적으로 어려운 공격면(challenge replay, code replay, ACR subsume, SLO chain state, redirect double-decode) 도 정확히 막혀 있다.

현재 가장 큰 위험은 코드보다 운영 위생(.env)이며, 다음으로 큰 위험은 CI 공급망(workflow PAT 자동 commit, 비공식 fork 의존성) + 외부 신뢰 모델(skin HTML, DNS, LDAP fork) 의 조합이다. Critical 14건 중 9건이 이 4축에 집중되어 있다.

이 4축이 해결되면 Risk Level 은 Medium 으로 즉시 떨어지며, 그 뒤에 남는 것은 정상적인 점진 개선 backlog 다.

감사 보고서 끝.